

WEB APPLICATION

VULNERABILITY ASSESSMENT & PENETRATION TEST

OWASP Juice Shop | 2026

Target Application	OWASP Juice Shop (TryHackMe Hosted VM)
Assessment Type	Black-box Vulnerability Assessment & Penetration Test
Platform	TryHackMe — https://tryhackme.com/room/owaspjuiceshop
Year	2026
Tools Used	Burp Suite, Nmap, ffuf, Gobuster
Classification	CONFIDENTIAL – Portfolio / Educational Use Only

1. Executive Summary

This report documents the findings from a personal Vulnerability Assessment and Penetration Test (VAPT) conducted against OWASP Juice Shop — an intentionally insecure web application designed for security education and training. The assessment was performed as a self-directed learning project via TryHackMe and covers all eight tasks in the room.

The assessment identified a range of vulnerabilities spanning several OWASP Top 10 (2021) categories including Injection, Broken Authentication, Sensitive Data Exposure, Broken Access Control, Security Misconfiguration, and Cross-Site Scripting (XSS).

1.1 Findings Overview

ID	Vulnerability	OWASP Category	Severity	Tool
F-01	SQL Injection – Admin Login Bypass	A03:2021	Critical	Burp Suite (Repeater)
F-02	SQL Injection – User Account Enumeration (Bender)	A03:2021	High	Burp Suite (Repeater)
F-03	Broken Authentication – Weak Password / Brute Force	A07:2021	High	Burp Suite (Intruder), Wordlist: best1050.txt (SecLists)
F-04	Sensitive Data Exposure – Confidential FTP Directory	A02:2021	High	Browser, Burp Suite
F-05	Broken Access Control – Admin Panel Exposed	A01:2021	High	Browser, JavaScript Beautifier (beautifier.io)
F-06	Reflected / DOM-Based XSS	A03:2021	Medium	Browser, Burp Suite
F-07	Insecure API Exposure – User Data via REST API	A01:2021	Medium	Burp Suite, Browser DevTools
F-08	Scoreboard / Hidden Route Discovery	A05:2021	Low	Browser, Burp Suite

1.2 Severity Distribution

Severity	Count	% of Total	Risk Level
Critical	1	12.5%	Immediate action required

High	4	50%	Urgent remediation needed
Medium	2	25%	Remediate within sprint cycle
Low	1	12.5%	Monitor and address in backlog

2. Project Overview

2.1 Objective

The objective of this personal project was to gain hands-on experience in web application penetration testing by exploiting a deliberately vulnerable application. All tasks in the TryHackMe OWASP Juice Shop room were completed, covering reconnaissance, injection attacks, authentication flaws, sensitive data exposure, broken access control, and cross-site scripting.

2.2 Scope

- Target: OWASP Juice Shop (TryHackMe VM)
- All 8 TryHackMe room tasks completed
- OWASP Top 10 vulnerabilities explored
- Tools: Burp Suite, Nmap, ffuf, Gobuster, browser DevTools

2.3 Methodology

The assessment followed a structured black-box penetration testing approach modelled on industry frameworks:

- Phase 1 – Reconnaissance: Passive and active information gathering, endpoint discovery
- Phase 2 – Scanning & Enumeration: Port scanning with Nmap, directory busting with ffuf/Gobuster
- Phase 3 – Exploitation: Manual exploitation of injection, auth, and access control flaws using Burp Suite
- Phase 4 – Post-Exploitation: Data extraction, privilege review, lateral movement simulation
- Phase 5 – Reporting: Documentation of findings with severity ratings, PoC, and remediation

2.4 Tools & Technologies

Tool	Purpose	Usage in this Project
Burp Suite Community	HTTP interception, manual exploitation	SQLi, XSS, API testing, Intruder brute force
Nmap	Network & port scanning	Service discovery on target VM
ffuf	Fast web fuzzer / directory discovery	Hidden endpoint and directory enumeration
Gobuster	Directory and DNS brute-forcing	Web directory and file enumeration
Browser DevTools	JS analysis, network inspection	Source code review, API discovery
beautifier.io	JavaScript de-obfuscation	Admin route discovery from minified JS

3. TryHackMe Task Completion Log

All 8 tasks in the OWASP Juice Shop room were completed. The table below summarises each task and its key learning outcomes.

Task	Topic	Key Activity	Learning Outcome
Task 1	Open for Business	Deploy VM, configure Burp Suite proxy	Environment setup, traffic interception fundamentals
Task 2	Injection	SQL injection via login form	Understanding SQLi payloads, authentication bypass
Task 3	Broken Authentication	Brute-force attack using Burp Intruder	Password attack techniques, wordlists, rate-limit absence
Task 4	Sensitive Data Exposure	FTP directory traversal, confidential file access	Data exposure, insecure file storage, directory browsing
Task 5	Broken Access Control	Admin panel via client-side route bypass	RBAC importance, client vs server-side authorisation
Task 6	XSS	Reflected/DOM XSS via search and review fields	Input sanitisation, output encoding, CSP
Task 7	Insecure API	Unauthenticated REST API user data access	API security, minimal data exposure, endpoint auth
Task 8	Exploration / Scoreboard	Accessing hidden scoreboard route	Hidden route discovery, security misconfiguration

4. Detailed Findings

Each finding below is documented with full technical details including reproduction steps, proof-of-concept evidence, impact assessment, and remediation recommendations.

4.1 [F-01] SQL Injection – Admin Login Bypass

Vulnerability	SQL Injection – Admin Login Bypass
OWASP Category	A03:2021 – Injection
Severity	Critical
Tool Used	Burp Suite (Repeater)
Description	The login endpoint is vulnerable to SQL injection. By injecting a crafted payload into the email field, the authentication logic is bypassed and attacker gains access to the administrator account without valid credentials.
Steps to Reproduce	1. Open Burp Suite and enable Intercept.2. Navigate to the Juice Shop login page.3. Enter any value for email and password, intercept the POST request.4. Send request to Repeater.5. Replace email field value with: ' OR 1=1--6. Forward the request and observe 200 OK response with admin session token.
Evidence / PoC	Payload: ' OR 1=1-- Response: 200 OK with JWT token for admin@juice-sh.op
Impact	Complete authentication bypass. Attacker gains full administrative access including user data, orders, and application configuration.
Remediation	Use parameterised queries / prepared statements. Implement input validation and sanitisation. Deploy a Web Application Firewall (WAF).

4.2 [F-02] SQL Injection – User Account Enumeration (Bender)

Vulnerability	SQL Injection – User Account Enumeration (Bender)
OWASP Category	A03:2021 – Injection
Severity	High
Tool Used	Burp Suite (Repeater)
Description	Individual user accounts can be accessed via SQL injection by supplying the target email with a comment sequence to nullify the password check.
Steps to Reproduce	1. Intercept the POST /api/Users/login request.2. Set email to: bender@juice-sh.op'--3. Set password to any value.4. Forward request and observe successful login as Bender.
Evidence / PoC	Payload: bender@juice-sh.op'-- Result: Authenticated session as Bender
Impact	Horizontal privilege escalation. Attacker can impersonate any registered user.
Remediation	Parameterised queries, strict input validation, account lockout after failed attempts.

4.3 [F-03] Broken Authentication – Weak Password / Brute Force

Vulnerability	Broken Authentication – Weak Password / Brute Force
OWASP Category	A07:2021 – Identification and Authentication Failures
Severity	High
Tool Used	Burp Suite (Intruder), Wordlist: best1050.txt (SecLists)
Description	The application does not implement account lockout or rate limiting. Weak admin credentials can be brute-forced using a common wordlist.
Steps to Reproduce	1. Intercept POST /api/Users/login.2. Send to Intruder, set password field as payload position.3. Load best1050.txt wordlist.4. Run attack; observe 200 response for successful credentials.
Evidence / PoC	Successful login after wordlist attack with password: admin123
Impact	Full account takeover for any account with a weak password.
Remediation	Enforce strong password policy. Implement account lockout, CAPTCHA, and multi-factor authentication (MFA).

4.4 [F-04] Sensitive Data Exposure – Confidential FTP Directory

Vulnerability	Sensitive Data Exposure – Confidential FTP Directory
OWASP Category	A02:2021 – Cryptographic Failures / Sensitive Data Exposure
Severity	High
Tool Used	Browser, Burp Suite
Description	An unauthenticated FTP directory is exposed through the application's About Us page. Sensitive files including confidential documents and acquisition letters are accessible without authentication.
Steps to Reproduce	1. Navigate to About Us page.2. Hover over the green link to reveal the FTP path.3. Navigate to /ftp/ directly.4. Browse and download sensitive .md and .pdf files.
Evidence / PoC	URL: http:///ftp/ File discovered: acquisitions.md
Impact	Exposure of confidential business data, internal documents, and potential credentials.
Remediation	Restrict FTP directory access with authentication. Remove sensitive files from web-accessible directories. Implement proper access controls.

4.5 [F-05] Broken Access Control – Admin Panel Exposed

Vulnerability	Broken Access Control – Admin Panel Exposed
OWASP Category	A01:2021 – Broken Access Control
Severity	High

Tool Used	Browser, JavaScript Beautifier (beautifier.io)
Description	The administration panel is accessible by guessing the client-side route. The path is exposed in obfuscated front-end JavaScript and lacks server-side authorisation enforcement.
Steps to Reproduce	1. View page source and copy JavaScript bundle to beautifier.io.2. Search for 'admin' in the beautified code.3. Discover route: /#/administration.4. Navigate to http:///#/administration.5. Access is granted without admin role verification.
Evidence / PoC	URL: http:///#/administration Result: Admin dashboard with all users and feedback
Impact	Any authenticated user can access the admin panel to modify or delete user accounts and reviews.
Remediation	Implement server-side role-based access control (RBAC). Do not rely on client-side route guards alone.

4.6 [F-06] Reflected / DOM-Based XSS

Vulnerability	Reflected / DOM-Based XSS
OWASP Category	A03:2021 – Injection (XSS)
Severity	Medium
Tool Used	Browser, Burp Suite
Description	The search and product review fields fail to sanitise user input, allowing injection of malicious scripts that execute in the context of other users' browsers.
Steps to Reproduce	1. Navigate to the search bar.2. Enter payload: 3. Observe alert popup confirming script execution.4. Test product review fields with similar payloads.
Evidence / PoC	Payload: Result: JavaScript alert executed
Impact	Session hijacking, credential theft, defacement, redirecting victims to malicious sites.
Remediation	Encode all output. Use Content Security Policy (CSP) headers. Sanitise input server-side and use modern frameworks that auto-escape HTML.

4.7 [F-07] Insecure API Exposure – User Data via REST API

Vulnerability	Insecure API Exposure – User Data via REST API
OWASP Category	A01:2021 – Broken Access Control
Severity	Medium
Tool Used	Burp Suite, Browser DevTools
Description	The REST API exposes internal user data including email addresses and hashed passwords without sufficient authorisation controls.

Steps to Reproduce	1. Open Burp Suite with intercept off and browse the application.2. Inspect captured API calls in HTTP History.3. Identify GET /api/Users/ endpoint.4. Send request directly; observe full user database returned.
Evidence / PoC	GET /api/Users/ Response: JSON array of all users with emails and password hashes
Impact	Mass user data enumeration. Hashed passwords can be subject to offline cracking attacks.
Remediation	Enforce authentication and authorisation on all API endpoints. Return only the minimum required data. Implement rate limiting.

4.8 [F-08] Scoreboard / Hidden Route Discovery

Vulnerability	Scoreboard / Hidden Route Discovery
OWASP Category	A05:2021 – Security Misconfiguration
Severity	Low
Tool Used	Browser, Burp Suite
Description	The application's challenge scoreboard is accessible via a hidden client-side route that reveals the full challenge list, completion status, and hints about other attack vectors.
Steps to Reproduce	1. Intercept application traffic in Burp.2. Observe XHR calls to REST scoreboard API.3. Navigate to /#/score-board.4. Full challenge list and hints are displayed.
Evidence / PoC	URL: http:///#/score-board Result: Full challenge scoreboard rendered
Impact	Information disclosure — reveals attack surface and aids in further enumeration.
Remediation	Restrict sensitive routes to authenticated admin users. Avoid exposing internal challenge/debug routes in production.

5. Reconnaissance & Enumeration Notes

5.1 Nmap Scan

Initial port scan to identify open services on the target machine:

```
nmap -sV -sC -p- <TARGET_IP> -oN juice_shop_scan.txt
```

Key services identified: HTTP (3000/tcp) — Node.js Express application

5.2 Directory Enumeration with ffuf

```
ffuf -w /usr/share/wordlists/dirb/common.txt -u http://<TARGET_IP>/FUZZ
```

Notable directories discovered: /ftp, /api, /assets, /#/administration

5.3 Directory Enumeration with Gobuster

```
gobuster dir -u http://<TARGET_IP> -w  
/usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
```

Gobuster confirmed FTP directory and REST API endpoints exposed without authentication.

5.4 Burp Suite Proxy Setup

Burp Suite was configured as an HTTP proxy to intercept and modify all application traffic:

- Proxy listener: 127.0.0.1:8080
- Browser configured to route traffic through Burp proxy
- Intercept set to OFF for passive logging during reconnaissance
- HTTP History used to identify endpoints, parameters, and authentication mechanisms

6. OWASP Top 10 (2021) Coverage

The following OWASP Top 10 categories were explored and validated during this assessment:

OWASP Category (2021)	Status	Finding Reference
A01 – Broken Access Control	Exploited	F-05, F-07
A02 – Cryptographic Failures	Exploited	F-04
A03 – Injection (SQLi, XSS)	Exploited	F-01, F-02, F-06
A04 – Insecure Design	Observed	General app architecture
A05 – Security Misconfiguration	Exploited	F-08
A06 – Vulnerable Components	In Scope	Outdated npm packages noted
A07 – Auth Failures	Exploited	F-03
A08 – Software & Data Integrity	Out of Scope	—
A09 – Security Logging Failures	Observed	No alerting on brute-force
A10 – SSRF	Out of Scope	—

7. Key Learnings & Skills Developed

7.1 Technical Skills

- Hands-on proficiency with Burp Suite for interception, repeater, and intruder modules
- Network scanning and service enumeration using Nmap
- Web directory and endpoint fuzzing with ffuf and Gobuster
- Manual SQL injection — error-based, boolean-based, and comment-sequence variants
- XSS payload crafting for reflected and DOM-based vulnerabilities
- REST API security testing and insecure endpoint identification
- JavaScript de-obfuscation for hidden route discovery
- Password brute-force attacks using curated wordlists (SecLists)

7.2 Security Concepts

- OWASP Top 10 (2021) — practical application of all major categories
- Authentication vs. authorisation — understanding the distinction and common failures
- Principle of least privilege and its absence in real-world scenarios
- Secure coding practices: parameterised queries, output encoding, CSP headers
- Security-by-design vs. security-as-an-afterthought

7.3 Reporting Skills

- Structured security report writing with severity ratings (Critical / High / Medium / Low)
- Proof-of-concept documentation with reproduction steps
- Remediation recommendations aligned to industry best practices
- Risk communication for both technical and non-technical audiences

8. Remediation Summary

The following remediation actions are recommended in priority order:

ID	Priority	Issue	Recommendation
F-01	Critical	SQL Injection – Auth Bypass	Implement parameterised queries and input validation
F-02	High	SQL Injection – Account Enum	Parameterised queries; generic error messages
F-03	High	Brute Force / Weak Password	Account lockout, MFA, strong password policy
F-04	High	FTP Sensitive Data Exposure	Restrict directory access; remove public-facing sensitive files
F-05	High	Broken Access Control – Admin	Enforce server-side RBAC on all restricted routes
F-06	Medium	Cross-Site Scripting (XSS)	Output encoding, Content Security Policy (CSP)
F-07	Medium	Insecure API Exposure	Authenticate all API endpoints; return minimal data
F-08	Low	Hidden Route / Scoreboard	Restrict sensitive routes; remove debug pages from production

9. Personal Notes & Self-Assessment

9.1 Challenges Encountered

Challenge	How I Overcame It	What I Learned
SQL INJECTION	Identified SQL query transmission from HTTP/POST request, showing a clear exploit. Payload passes TRUE value to SQL query and comments '--' all the other query requests, hence, selecting the first user.	Query sanitization is necessary before a payload POST request.
CRACKING PASSWORD	Identification of password verification process, reconnaissance for user's email to be targeted, targeted bruteforce attack using a large as well as a small wordlist of commonly used passwords. Using the Burpsuite Intruder/ffuf to uncover the password (automated)	Reconnaissance can uncover a lot about a user's password formation, brute-force attack is only as good as the initial start and not having a small dataset to brute force can lead to unnecessary processing along with loss of time. Hence, choice of wordlist should be considered. Passwords must follow strict security guidelines.
DOWNLOAD RESTRICTED FILE (.BAK NOT ALLOWED, .MD ALLOWED)	Used "Poison Null Byte (%.00)" which allowed me to download the restricted .PDF files too.	Having control over restricted files is necessary and should not be accessed from unsecure servers, mechanisms should be in place which block the read/write operations on such files. A lot of harmless exploits aren't actually harmless.
HIDDEN ROUTE EXPLORATION	Used "ffuf" to FUZZ out the hidden pages, multiple pages not accessible from the website dashboard were discovered.	Reconnaissance can lead to vital information being leaked along with pages which are not easily accessible to general users.
INSECURE API/ IDOR	Burpsuite network capture which was used to forward requests and identify multiple hidden api calls which take	Accessing other user's data requires knowing the details of how data is being fetched from the database and how

	place under a simple GET request. Using Burpsuite repeater for manual data extraction while making changes to the header and payload	each user's data is stored. Burpsuite can provide certain insights into this matter by intercepting GET/POST requests.
--	---	--

9.2 Evidence Log – Flags Captured

Task	Document
SQL INJECTION	1.png, 2.png , 3.png, 4.png, 5.png, 6.png
CRACK PASSWORD & RESET PASSWORD (WITHOUT CREDENTIALS)	7.png, 8.png, 9.png, 10.png, 11.png
ACCESS RESTRICTED DOCUMENTS	12.png, 13.png, 14.png, 15.png, 16.png
PERFORM RECONNAISSANCE FOR UNAUTHORIZED ACCOUNT ACCESS	17.png, 18.png
DOWNLOAD RESTRICTED FILES	19.png, 20.png
PRIVILEGE ESCALTION	21.png, 22.png
IDOR/ ACCESS OTHER USER'S DATA	23.png, 24.png
EXPLOIT ELEVATED PRIVILEGE	25.png
DOM XSS EXPLOIT	26.png
PERSISTENT XSS	27.png, 28.png, 29.png

Note: All screenshot evidence referenced above can be found in the [/images](#) folder included in this project repository.

Appendix: Useful References

- OWASP Top 10 (2021): <https://owasp.org/www-project-top-ten/>
- OWASP Juice Shop Project: <https://owasp.org/www-project-juice-shop/>
- TryHackMe Room: <https://tryhackme.com/room/owaspjuiceshop>
- SecLists Wordlists: <https://github.com/danielmiessler/SecLists>
- Burp Suite Documentation: <https://portswigger.net/burp/documentation>
- Nmap Reference: <https://nmap.org/book/man.html>
- ffuf GitHub: <https://github.com/ffuf/ffuf>
- Gobuster GitHub: <https://github.com/OJ/gobuster>

This document was created as part of a personal cybersecurity learning portfolio. All testing was conducted in a controlled, legal lab environment on an intentionally vulnerable application.